

cquict2025 / coit20246y26t1-project-coit20246-sydb1-masoodjazib-1

🔍 Type ↵ to search

+

<> Code

Issues

Pull requests

Agents

Actions

Projects

Wiki

Security and quality

Insights

Settings

coit20246y26t1-project-coit20246-sydb1-masoodjazib-1 / security.md

jazib1709 Update security.md

ffdc684 · now

History

Preview

Code

Blame

Raw

Risk Assessment and Security Controls

Risk Assessment

[View risk assessment spreadsheet](#)

Security Controls

The TVAMatrix spreadsheet was used to complete a mini cyber security risk assessment of Sydney TaxCare Services. The security assessment was in the small business network on the OpenWRT that included the router/ firewall, hosted webpage, the staffs workstations, the management and the sensitive business data.

The following were the key assets that were taken into account in the assessment.

Asset	Asset Type	Reason for Including
Client tax records	Data	Contains sensitive client and financial information
Staff login credentials	Data	Used to access systems and administrative services
Website content files	Data	Public-facing business information hosted on OpenWRT
Firewall configuration	Data/configuration	Controls access to HTTP, SSH, ICMP, and management services
OpenWRT router/firewall	Hardware/software	Main network security device
Web server service	Software/service	Hosts the business website
Staff workstations	Hardware	Used for daily business operations
IT support workstation	Hardware	Used for administration and troubleshooting

The risk factors considered when conducting the risk assessment included the unauthorised access, poor passwords, data interception, malware, phishing, firewall misconfiguration, denial of service, service exposure, insider abuse and loss of availability.

Client tax records were determined as the riskiest data asset. This asset was rated the highest as Sydney TaxCare Services deals with information related to accounting and tax. In case of exposure, modification or loss of client tax records, then the business might end up losing privacy, losing money, tarnished reputation and client confidence.

The risk assessment is assessed by the practical work carried out in the project. The firewall rules showed that it was possible to regulate access to: HTTP, SSH, ICMP and management interface. The hardening measures demonstrated the impact of default credentials, SSH authentication, password storage, as well as unnecessary services on the security of systems. The analysis of the traffic also revealed the importance of encrypted communication, as the HTTP traffic supports readable information whereas in SSS session contents are encrypted.

Security Controls

Client tax records is the riskiest piece of data that has been targeted to be the subject of security controls. This information is sensitive as it might consist of client identity, financial, tax information and business records. The following recommendations are the controls that would be applied to mitigate the risk on this asset.

Control 1: Strong Access Control and SSH Key-Based Administration

There should be access control so that only authorised users can access systems containing or dealing with client tax records. Working with OpenWRT should be an access of IT support users only. The adoption of the use of SSH keys that is founded on authentication should be embraced as opposed to the use of passwords alone.

This project used SSH key-based login which has been configured and tested on OpenWRT. This enhances security as an attacker would need the use of a password that would not be the private key to get SSH access. Firewall testing also included changing the SSH port thus reducing vulnerability to rudimentary automated attack against the default SSH port.

This control minimises the chances of unauthorized access to router/firewall, and associated network services. In cases where the attacker finds it difficult to access the administrative services, the probability of manipulating firewall settings, intercepting traffic and gaining access to systems containing client data is very low.

One such disadvantage is that SSH keys would need to be managed. The user can lose his/her access in the event of the personal key being lost. Should a private key be stolen, then it can be abusively used unless it is revoked as soon as possible.

Control 2: Firewall Filtering and Network Segmentation

Unnecessary traffic should be limited by applying firewall filtering. The production network is designed in such a way that it isolates the staff LAN and web server DMZ. The staff LAN uses 98.10.10.0/24 , while the web server DMZ uses 72.10.20.0/24 . This seclusion is helpful in protecting internal personnel staffing procedures and client knowledge against easy access by the externally visible web server.

Firewall rules were set to give a test to the access to the lab environment via HTTP, SSH, ICMP, and the management interface. The blocking of the HTTP meant that access to the site can be managed. ICMP blocking demonstrated that it is possible to decrease minimum visibility of the network. Limitations of SSH and management interface showed how administrative privileges can be reduced to the bare minimum.

Control 3: Encrypted Communication and Regular Backup

Encrypted message must be used to access and transfer sensitive data in an administrative. Traffic analysis showed that the HTTP traffic has readable request and response data in Wireshark and SSH traffic encrypts session data. SSH must be employed to access the production server in case of administrative access and HTTPS must be employed with the business web site rather than using plain HTTP.

On a regular basis, client tax records, web and firewall configurations must also be backed. The backups should be kept somewhere safe and it should be inspected frequently. This will save the business in case of the loss, corruption or malware infection of data. This control minimizes the chances of interception of data and loss of data. The encryption helps in securing data when transmitting it through the network and backup helps in retrieving the data in case of an incidence.

Among the disadvantages, there is that HTTPS certificates, backup storage and recovery testing is time-consuming and administratively intensive. The procedures must also be laid properly among the staffs so that they can ensure the backups are correctly carried out and when they are required the procedure is restored.

Summary of Recommended Controls

Control	Risk Reduced	Implementation in Scenario
Strong access control and SSH key authentication	Unauthorised administrative access	Limit access to IT support, use SSH keys to access the OpenWRT administration
Firewall filtering and network segmentation	Access and movement laterally	Isolated staff LAN and DMZ, limit HTTP, SSH, ICMP, and administration
Encrypted communication and regular backup	Information breach, Data loss	Apply SSH/HTTPS and have a safe backup of client records and settings

The controls may be combined to reduce the main risks of client tax records such as unauthorised access and exposure, in transit, and recovery in the event of an incident.